

The European Data Protection Board

Having regard to Article 70 (1)(e) of the Regulation 2016/679/EU of the European Parliament and of

the Council of 27 April 2016 on the protection of natural persons with regard to the processing of

personal data and on the free movement of such data, and repealing Directive 95/46/EC, (hereinafter “GDPR”),

Having regard to the EEA Agreement and in particular to Annex XI and Protocol 37 thereof, as amended

by the Decision of the EEA joint Committee No 154/2018 of 6 July 2018¹,

Having regard to Article 12 and Article 22 of its Rules of Procedure,

Having regard to the Article 29 Working Party Guidelines on consent under Regulation 2016/679,

WP259 rev.01,

HAS ADOPTED THE FOLLOWING GUIDELINES

0 PREFACE

On 10 April 2018 the Article 29 Working Party adopted its Guidelines on consent under Regulation

2016/679 (WP259.01), which were endorsed by the European Data Protection Board (hereinafter

“EDPB”) at its first Plenary meeting. This document is a slightly updated version of those Guidelines.

Any reference to the WP29 Guidelines on consent (WP259 rev.01) should from now on be interpreted

as a reference to these guidelines.

The EDPB has noticed that there was a need for further clarifications, specifically regarding two

questions:

1

The validity of consent provided by the data subject when interacting with so-called “cookie walls”;

2

The example 16 on scrolling and consent.

The paragraphs concerning these two issues have been revised and updated, while the rest of the

document was left unchanged, except for editorial changes. The revision concerns, more specifically:

- Section on Conditionality (paragraphs 38 - 41).
- Section on Unambiguous indication of wishes (paragraph 86)

1 INTRODUCTION

1.

These Guidelines provide a thorough analysis of the notion of consent in Regulation 2016/679, the

General Data Protection Regulation (hereafter: GDPR). The concept of consent as used in the Data

¹

References to “Member States” made throughout this document should be understood as references to “EEA

Member States”.adopted

5

Protection Directive (hereafter: Directive 95/46/EC) and in the e-Privacy Directive to date, has evolved.

The GDPR provides further clarification and specification of the requirements for obtaining and demonstrating valid consent. These Guidelines focus on these changes, providing practical guidance to ensure compliance with the GDPR and building upon the Article 29 Working Party Opinion 15/2011 on consent. The obligation is on controllers to innovate to find new solutions that operate within the parameters of the law and better support the protection of personal data and the interests of data subjects.

2.

Consent remains one of six lawful bases to process personal data, as listed in Article 6 of the GDPR.²

When initiating activities that involve processing of personal data, a controller must always take time

to consider what would be the appropriate lawful ground for the envisaged processing.

3.

Generally, consent can only be an appropriate lawful basis if a data subject is offered control and is

offered a genuine choice with regard to accepting or declining the terms offered or declining them

without detriment. When asking for consent, a controller has the duty to assess whether it will meet

all the requirements to obtain valid consent. If obtained in full compliance with the GDPR, consent is

a tool that gives data subjects control over whether or not personal data concerning them will be

processed. If not, the data subject's control becomes illusory and consent will be an invalid basis for

processing, rendering the processing activity unlawful.³

4.

The existing Article 29 Working Party (WP29) Opinions on consent⁴ remain relevant, where consistent

with the new legal framework, as the GDPR codifies existing WP29 guidance and general good practice

and most of the key elements of consent remain the same under the GDPR. Therefore, in this

document, the EDPB expands upon and completes earlier Article 29 Working Party Opinions on specific

topics that include reference to consent under Directive 95/46/EC, rather than replacing them.

5.

As the WP29 stated in its Opinion 15/2011 on the definition on consent, inviting people to accept a

data processing operation should be subject to rigorous requirements, since it concerns the fundamental rights of data subjects and the controller wishes to engage in a processing operation that

would be unlawful without the data subject's consent.⁵ The crucial role of consent is underlined by Articles 7 and 8 of the Charter of Fundamental Rights of the European Union. Furthermore, obtaining consent also does not negate or in any way diminish the controller's obligations to observe the principles of processing enshrined in the GDPR, especially Article 5 of the GDPR with regard to fairness, necessity and proportionality, as well as data quality. Even if the processing of personal data is based on consent of the data subject, this would not legitimise collection of data, which is not necessary in relation to a specified purpose of processing and be fundamentally unfair.⁶

² Article 9 GDPR provides a list of possible exemptions to the ban on processing special categories of data. One of the exemptions listed is the situation where the data subject provides explicit consent to the use of this data.

³ See also Article 29 Working Party Opinion 15/2011 on the definition of consent (WP 187), pp. 6-8, and/or Opinion 06/2014 on the notion of legitimate interests of the data controller under Article 7 of Directive 95/46/EC (WP 217), pp. 9, 10, 13 and 14.

⁴ Most notably, Opinion 15/2011 on the definition of consent (WP 187).

⁵ Opinion 15/2011, page on the definition of consent (WP 187), p. 8.

⁶ See also Opinion 15/2011 on the definition of consent (WP 187), and Article 5 GDPR.adopted

⁶

6.

Meanwhile, the EDPB is aware of the review of the ePrivacy Directive (2002/58/EC). The notion of consent in the draft ePrivacy Regulation remains linked to the notion of consent in the GDPR.⁷

Organisations are likely to need consent under the ePrivacy instrument for most online marketing messages or marketing calls, and online tracking methods including by the use of cookies or apps or other software. The EDPB has already provided recommendations and guidance to the European legislator on the Proposal for a Regulation on ePrivacy.⁸

7.

With regard to the existing e-Privacy Directive, the EDPB notes that references to the repealed Directive 95/46/EC shall be construed as references to the GDPR.⁹ This also applies to references to consent in the current Directive 2002/58/EC, as the ePrivacy Regulation will not (yet) be in force from 25 May 2018. According to Article 95 GDPR, additional obligations in relation to processing in connection with the provision of publicly available electronic communications services in public communication networks shall not be imposed insofar the e-Privacy Directive imposes specific

obligations with the same objective. The EDPB notes that the requirements for consent under the GDPR are not considered to be an 'additional obligation', but rather as preconditions for lawful processing. Therefore, the GDPR conditions for obtaining valid consent are applicable in situations falling within the scope of the e-Privacy Directive.

2 CONSENT IN ARTICLE 4(11) OF THE GDPR

8.

Article 4(11) of the GDPR defines consent as: *"any freely given, specific, informed and unambiguous indication of the data subject's wishes by which he or she, by a statement or by a clear affirmative action, signifies agreement to the processing of personal data relating to him or her."*

9.

The basic concept of consent remains similar to that under the Directive 95/46/EC and consent is one of the lawful grounds on which personal data processing has to be based, pursuant to Article 6 of the GDPR.¹⁰ Besides the amended definition in Article 4(11), the GDPR provides additional guidance in Article 7 and in recitals 32, 33, 42, and 43 as to how the controller must act to comply with the main elements of the consent requirement.

7

According to Article 9 of the proposed ePrivacy Regulation, the definition of and the conditions for consent provided for in Articles 4(11) and Article 7 of the GDPR apply.

8

See [EDPB statement on ePrivacy - 25/05/2018](#) and [EDPB Statement 3/2019 on an ePrivacy regulation](#).

9

See Article 94 GDPR.

10

Consent was defined in Directive 95/46/EC as *"any freely given specific and informed indication of his wishes by which the data subject signifies his agreement to personal data relating to him being processed"* which must be *'unambiguously given'* in order to make the processing of personal data legitimate (Article 7(a) of Directive 95/46/EC)). See WP29 Opinion 15/2011 on the definition of consent (WP 187) for examples on the appropriateness of consent as lawful basis. In this Opinion, WP29 has provided guidance to distinguish where consent is an appropriate lawful basis from those where relying on the legitimate interest ground (perhaps with an opportunity to opt out) is sufficient or a contractual relation would be recommended. See also WP29 Opinion 06/2014, paragraph III.1.2, p. 14 and further. Explicit consent is also one of the exemptions to the prohibition on the processing of special categories of data: See Article 9 GDPR.adopted

7

10. Finally, the inclusion of specific provisions and recitals on the withdrawal of consent confirms that consent should be a reversible decision and that there remains a degree of control on the side of the data subject.

3 ELEMENTS OF VALID CONSENT

11. Article 4(11) of the GDPR stipulates that consent of the data subject means any:

- freely given,
- specific,
- informed and
- unambiguous indication of the data subject's wishes by which he or she, by a statement or by a clear affirmative action, signifies agreement to the processing of personal data relating to him or her.

12. In the sections below, it is analysed to what extent the wording of Article 4(11) requires controllers to change their consent requests/forms, in order to ensure compliance with the GDPR.¹¹

3.1 Free / freely given¹²

13. The element “free” implies real choice and control for data subjects. As a general rule, the GDPR

prescribes that if the data subject has no real choice, feels compelled to consent or will endure negative

consequences if they do not consent, then consent will not be valid.¹³ If consent is bundled up as a

non-negotiable part of terms and conditions it is presumed not to have been freely given.

Accordingly,

consent will not be considered to be free if the data subject is unable to refuse or withdraw his or her

consent without detriment.¹⁴ The notion of imbalance between the controller and the data subject is

also taken into consideration by the GDPR.

14. When assessing whether consent is freely given, one should also take into account the specific

situation of tying consent into contracts or the provision of a service as described in Article 7(4). Article

7(4) has been drafted in a non-exhaustive fashion by the words “inter alia”, meaning that there may

be a range of other situations, which are caught by this provision. In general terms, any element of

¹¹ For guidance with regard to ongoing processing activities based on consent in Directive 95/46, see chapter 7 of this document and recital 171 of the GDPR.

¹² In several opinions, the Article 29 Working Party has explored the limits of consent in situations where it cannot be freely given. This was notably the case in its Opinion 15/2011 on the definition of consent (WP 187), Working Document on the processing of personal data relating to health in electronic health records (WP 131), Opinion 8/2001 on the processing of personal data in the employment context (WP48), and Second opinion 4/2009 on processing of data by the World Anti-Doping Agency (WADA) (International Standard for the Protection of Privacy and Personal Information, on related provisions of the WADA Code and on other privacy issues in the context of the fight against doping in sport by WADA and (national) anti-doping organizations (WP 162).

¹³ See Opinion 15/2011 on the definition of consent (WP187), p. 12.

¹⁴ See Recitals 42, 43 GDPR and WP29 Opinion 15/2011 on the definition of consent, adopted on 13 July 2011,

(WP 187), p. 12.adopted

8

inappropriate pressure or influence upon the data subject (which may be manifested in many different ways) which prevents a data subject from exercising their free will, shall render the consent invalid.

15. Example 1: A mobile app for photo editing asks its users to have their GPS localisation activated for the use of its services. The app also tells its users it will use the collected data for behavioural advertising purposes. Neither geolocalisation or online behavioural advertising are necessary for the provision of the photo editing service and go beyond the delivery of the core service provided. Since users cannot use the app without consenting to these purposes, the consent cannot be considered as being freely given.

3.1.1 Imbalance of power

16. Recital 43¹⁵ clearly indicates that it is unlikely that **public authorities** can rely on consent for processing as whenever the controller is a public authority, there is often a clear imbalance of power in the relationship between the controller and the data subject. It is also clear in most cases that the data subject will have no realistic alternatives to accepting the processing (terms) of this controller. The EDPB considers that there are other lawful bases that are, in principle, more appropriate to the activity of public authorities.¹⁶

17. Without prejudice to these general considerations, the use of consent as a lawful basis for data processing by public authorities is not totally excluded under the legal framework of the GDPR. The following examples show that the use of consent can be appropriate under certain circumstances.

18. Example 2: A local municipality is planning road maintenance works. As the road works may disrupt traffic for a long time, the municipality offers its citizens the opportunity to subscribe to an email list to receive updates on the progress of the works and on expected delays. The municipality makes clear that there is no obligation to participate and asks for consent to use email addresses for this (exclusive) purpose. Citizens that do not consent will not miss out on any core service of the municipality or the exercise of any right, so they are able to give or refuse their consent to this use of data freely. All

information on the road works will also be available on the municipality's website.

19. Example 3: An individual who owns land needs certain permits from both her local municipality and

from the provincial government under which the municipality resides. Both public bodies require the same information for issuing their permit, but are not accessing each other's databases. Therefore, both ask for the same information and the land owner sends out her details to both public bodies. The municipality and the provincial authority ask for her consent to merge the files, to avoid duplicate procedures and correspondence. Both public bodies ensure that this is optional and that the permit requests will still be processed separately if she decides not to consent to the merger of her data. The land owner is able to give consent to the authorities for the purpose of merging the files freely.

¹⁵

Recital 43 GDPR states: *"In order to ensure that consent is freely given, consent should not provide a valid legal ground for the processing of personal data in a specific case where there is a clear imbalance between the data subject and the controller, in particular where the controller is a public authority and it is therefore unlikely that consent was freely given in all the circumstances of that specific situation. (...)".*

¹⁶

See Article 6 GDPR, notably paragraphs (1c) and (1e).adopted

9

20. Example 4: A public school asks students for consent to use their photographs in a printed student magazine. Consent in these situations would be a genuine choice as long as students will not be denied education or services and could refuse the use of these photographs without any detriment.¹⁷

21. An imbalance of power also occurs in the **employment** context.¹⁸ Given the dependency that results from the employer/employee relationship, it is unlikely that the data subject is able to deny his/her employer consent to data processing without experiencing the fear or real risk of detrimental effects as a result of a refusal. It is unlikely that an employee would be able to respond freely to a request for consent from his/her employer to, for example, activate monitoring systems such as camera observation in a workplace, or to fill out assessment forms, without feeling any pressure to consent.¹⁹

Therefore, the EDPB deems it problematic for employers to process personal data of current or future employees on the basis of consent as it is unlikely to be freely given. For the majority of such data processing at work, the lawful basis cannot and should not be the consent of the employees (Article

6(1)(a)) due to the nature of the relationship between employer and employee.²⁰

22. However, this does not mean that employers can never rely on consent as a lawful basis for processing.

There may be situations when it is possible for the employer to demonstrate that consent actually is

freely given. Given the imbalance of power between an employer and its staff members, employees

can only give free consent in exceptional circumstances, when it will have no adverse consequences at

all whether or not they give consent.²¹

23. Example 5: A film crew is going to be filming in a certain part of an office. The employer asks all the

employees who sit in that area for their consent to be filmed, as they may appear in the background

of the video. Those who do not want to be filmed are not penalised in any way but instead are given

equivalent desks elsewhere in the building for the duration of the filming.

24. Imbalances of power are not limited to public authorities and employers, they may also occur in other

situations. As highlighted by the WP29 in several Opinions, consent can only be valid if the data subject

is able to exercise a real choice, and there is no risk of deception, intimidation, coercion or significant

negative consequences (e.g. substantial extra costs) if he/she does not consent. Consent will not be

free in cases where there is any element of compulsion, pressure or inability to exercise free will.

¹⁷

For the purposes of this example, a public school means a publically funded school or any educational facility

that qualifies as a public authority or body by national law.

¹⁸

See also Article 88 GDPR, where the need for protection of the specific interests of employees is emphasised

and a possibility for derogations in Member State law is created. See also Recital 155.

¹⁹

See Opinion 15/2011 on the definition of consent (WP 187), pp. 12-14 , Opinion 8/2001 on the processing of

personal data in the employment context (WP 48), Chapter 10, Working document on the surveillance of electronic communications in the workplace (WP 55), paragraph 4.2 and Opinion 2/2017 on data processing at

work (WP 249), paragraph 6.2.

²⁰

See Opinion 2/2017 on data processing at work, page 6-7.

²¹

See also Opinion 2/2017 on data processing at work (WP249), paragraph 6.2.adopted

10

3.1.2

Conditionality

25. To assess whether consent is freely given, Article 7(4) GDPR plays an important role.²²

26. Article 7(4) GDPR indicates that, inter alia, the situation of “bundling” consent with acceptance of

terms or conditions, or “tying” the provision of a contract or a service to a request for consent to

process personal data that are not necessary for the performance of that contract or service, is

considered highly undesirable. If consent is given in this situation, it is presumed to be not freely given

(recital 43). Article 7(4) seeks to ensure that the purpose of personal data processing is not disguised

nor bundled with the provision of a contract of a service for which these personal data are not necessary. In doing so, the GDPR ensures that the processing of personal data for which consent is sought cannot become directly or indirectly the counter-performance of a contract. The two lawful bases for the lawful processing of personal data, i.e. consent and contract cannot be merged and blurred.

27. Compulsion to agree with the use of personal data additional to what is strictly necessary limits data subject's choices and stands in the way of free consent. As data protection law is aiming at the protection of fundamental rights, an individual's control over their personal data is essential and there is a strong presumption that consent to the processing of personal data that is unnecessary, cannot be seen as a mandatory consideration in exchange for the performance of a contract or the provision of a service.

28. Hence, whenever a request for consent is tied to the performance of a contract by the controller, a data subject that does not wish to make his/her personal data available for processing by the controller runs the risk to be denied services they have requested.

29. To assess whether such a situation of bundling or tying occurs, it is important to determine what the scope of the contract is and what data would be necessary for the performance of that contract.

30. According to Opinion 06/2014 of WP29, the term "necessary for the performance of a contract" needs to be interpreted strictly. The processing must be necessary to fulfil the contract with each individual data subject. This may include, for example, processing the address of the data subject so that goods purchased online can be delivered, or processing credit card details in order to facilitate payment. In the employment context, this ground may allow, for example, the processing of salary information and bank account details so that wages can be paid.²³ There needs to be a direct and objective link between the processing of the data and the purpose of the execution of the contract.

31. If a controller seeks to process personal data that are in fact necessary for the performance of a contract, then consent is not the appropriate lawful basis.²⁴

²²

Article 7(4) GDPR: "*When assessing whether consent is freely given, utmost account shall be taken of whether, inter alia, the performance of a contract, including the provision of a service, is conditional on consent to the processing of personal data that is not necessary for the performance of that contract.*" See also Recital 43 GDPR,

that states: “[...] Consent is presumed not to be freely given if it does not allow separate consent to be given to different personal data processing operations despite it being appropriate in the individual case, or if the performance of a contract, including the provision of a service, is dependent on the consent, despite such consent not being necessary for such performance.”

²³

For more information and examples, see Opinion 06/2014 on the notion of legitimate interest of the data controller under Article 7 of Directive 95/46/EC, adopted by WP29 on 9 April 2014, p. 16-17. (WP 217).

²⁴

The appropriate lawful basis could then be Article 6(1)(b) (contract).^{adopted}

11

32. Article 7(4) is only relevant where the requested data are **not** necessary for the performance of the contract, (including the provision of a service), and the performance of that contract is made conditional on the obtaining of these data on the basis of consent. Conversely, if processing **is** necessary to perform the contract (including to provide a service), then Article 7(4) does not apply.

33. Example 6: A bank asks customers for consent to allow third parties to use their payment details for direct marketing purposes. This processing activity is not necessary for the performance of the contract with the customer and the delivery of ordinary bank account services. If the customer’s refusal to consent to this processing purpose would lead to the denial of banking services, closure of the bank account, or, depending on the case, an increase of the fee, consent cannot be freely given.

34. The choice of the legislator to highlight conditionality, amongst others, as a presumption of a lack of freedom to consent, demonstrates that the occurrence of conditionality must be carefully scrutinized.

The term “utmost account” in Article 7(4) suggests that special caution is needed from the controller

when a contract (which could include the provision of a service) has a request for consent to process personal data tied to it.

35. As the wording of Article 7(4) is not construed in an absolute manner, there might be very limited space for cases where this conditionality would not render the consent invalid. However, the word

“presumed” in Recital 43 clearly indicates that such cases will be highly exceptional.

36. In any event, the burden of proof in Article 7(4) is on the controller.²⁵ This specific rule reflects the general principle of accountability, which runs throughout the GDPR. However, when Article 7(4)

applies, it will be more difficult for the controller to prove that consent was given freely by the data subject.²⁶

37. The controller could argue that his organisation offers data subjects genuine choice if they were able to choose between a service that includes consenting to the use of personal data for additional

purposes on the one hand, and an equivalent service offered by the same controller that does not involve consenting to data use for additional purposes on the other hand. As long as there is a possibility to have the contract performed or the contracted service delivered by this controller without consenting to the other or additional data use in question, this means there is no longer a conditional service. However, both services need to be genuinely equivalent.

38. The EDPB considers that consent cannot be considered as freely given if a controller argues that a choice exists between its service that includes consenting to the use of personal data for additional purposes on the one hand, and an equivalent service offered by a different controller on the other hand. In such a case, the freedom of choice would be made dependent on what other market players do and whether an individual data subject would find the other controller's services genuinely

²⁵ See also Article 7(1) GDPR, which states that the controller needs to demonstrate that the data subject's agreement was freely given.

²⁶ To some extent, the introduction of this paragraph is a codification of existing WP29 guidance. As described in

Opinion 15/2011, when a data subject is in a situation of dependence on the data controller – due to the nature of the relationship or to special circumstances – there may be a strong presumption that freedom to consent is

limited in such contexts (e.g. in an employment relationship or if the collection of data is performed by a public authority). With Article 7(4) in force, it will be more difficult for the controller to prove that consent was given

freely by the data subject. See: Article 29 Working Party Opinion 15/2011 on the definition of consent (WP 187),

pp. 12-17.adopted

12

equivalent. It would furthermore imply an obligation for controllers to monitor market developments

to ensure the continued validity of consent for their data processing activities, as a competitor may

alter its service at a later stage. Hence, using this argument means a consent relying on an alternative

option offered by a third party fails to comply with the GDPR, meaning that a service provider cannot

prevent data subjects from accessing a service on the basis that they do not consent.

39. In order for consent to be freely given, access to services and functionalities must not be made

conditional on the consent of a user to the storing of information, or gaining of access to information

already stored, in the terminal equipment of a user (so called cookie walls)²⁷.

40. Example 6a: A website provider puts into place a script that will block content from being visible except

for a request to accept cookies and the information about which cookies are being set and for what purposes data will be processed. There is no possibility to access the content without clicking on the “Accept cookies” button. Since the data subject is not presented with a genuine choice, its consent is not freely given.

41. This does not constitute valid consent, as the provision of the service relies on the data subject clicking the “Accept cookies” button. It is not presented with a genuine choice.

3.1.3 Granularity

42. A service may involve multiple processing operations for more than one purpose. In such cases, the data subjects should be free to choose which purpose they accept, rather than having to consent to a bundle of processing purposes. In a given case, several consents may be warranted to start offering a service, pursuant to the GDPR.

43. Recital 43 clarifies that consent is presumed not to be freely given if the process/procedure for obtaining consent does not allow data subjects to give separate consent for personal data processing operations respectively (e.g. only for some processing operations and not for others) despite it being appropriate in the individual case. Recital 32 states, “ *Consent should cover all processing activities carried out for the same purpose or purposes. When the processing has multiple purposes, consent should be given for all of them*” .

44. If the controller has conflated several purposes for processing and has not attempted to seek separate consent for each purpose, there is a lack of freedom. This granularity is closely related to the need of consent to be specific, as discussed in section 3.2 further below. When data processing is done in pursuit of several purposes, the solution to comply with the conditions for valid consent lies in granularity, i.e. the separation of these purposes and obtaining consent for each purpose.

45. Example 7: Within the same consent request a retailer asks its customers for consent to use their data to send them marketing by email and also to share their details with other companies within their group. This consent is not granular as there is no separate consents for these two separate purposes, therefore the consent will not be valid. In this case, a specific consent should be collected to send the contact details to commercial partners. Such specific consent will be deemed valid for each partner (see also section 3.3.1), whose identity has been provided to the data subject at the time of the

collection of his or her consent, insofar as it is sent to them for the same purpose (in this example: a marketing purpose).

²⁷

As clarified above, the GDPR conditions for obtaining valid consent are applicable in situations falling within the scope of the e-Privacy Directive.^{adopted}

13

3.1.4 Detriment

46. The controller needs to demonstrate that it is possible to refuse or withdraw consent without detriment (recital 42). For example, the controller needs to prove that withdrawing consent does not

lead to any costs for the data subject and thus no clear disadvantage for those withdrawing consent.

47. Other examples of detriment are deception, intimidation, coercion or significant negative

consequences if a data subject does not consent. The controller should be able to prove that the data

subject had a free or genuine choice about whether to consent and that it was possible to withdraw

consent without detriment.

48. If a controller is able to show that a service includes the possibility to withdraw consent without any

negative consequences e.g. without the performance of the service being downgraded to the

detriment of the user, this may serve to show that the consent was given freely. The GDPR does not

preclude all incentives but the onus would be on the controller to demonstrate that consent was still

freely given in all the circumstances.

49. Example 8: When downloading a lifestyle mobile app, the app asks for consent to access the phone's

accelerometer. This is not necessary for the app to work, but it is useful for the controller who wishes

to learn more about the movements and activity levels of its users. When the user later revokes that

consent, she finds out that the app now only works to a limited extent. This is an example of detriment

as meant in Recital 42, which means that consent was never validly obtained (and thus, the controller

needs to delete all personal data about users' movements collected this way).

50. Example 9: A data subject subscribes to a fashion retailer's newsletter with general discounts. The

retailer asks the data subject for consent to collect more data on shopping preferences to tailor the

offers to his or her preferences based on shopping history or a questionnaire that is voluntary to fill

out. When the data subject later revokes consent, he or she will receive non-personalised fashion

discounts again. This does not amount to detriment as only the permissible incentive was lost.

51. Example 10: A fashion magazine offers readers access to buy new make-up products before the official launch.

52. The products will shortly be made available for sale, but readers of this magazine are offered an exclusive preview of these products. In order to enjoy this benefit, people must give their postal address and agree to subscription on the mailing list of the magazine. The postal address is necessary for shipping and the mailing list is used for sending commercial offers for products such as cosmetics or t-shirts year round.

53. The company explains that the data on the mailing list will only be used for sending merchandise and paper advertising by the magazine itself and is not to be shared with any other organisation.

54. In case the reader does not want to disclose their address for this reason, there is no detriment, as the products will be available to them anyway.

3.2 Specific

55. Article 6(1)(a) confirms that the consent of the data subject must be given in relation to “one or more specific” purposes and that a data subject has a choice in relation to each of them.²⁸ The requirement

²⁸ Further guidance on the determination of ‘purposes’ can be found in Opinion 3/2013 on purpose limitation (WP 203).adopted

14

that consent must be ‘specific’ aims to ensure a degree of user control and transparency for the data

subject. This requirement has not been changed by the GDPR and remains closely linked to the

requirement of ‘informed’ consent. At the same time, it must be interpreted in line with the requirement for ‘granularity’ to obtain ‘free’ consent.²⁹ In sum, to comply with the element of ‘specific’

the controller must apply:

i

Purpose specification as a safeguard against function creep,

ii Granularity in consent requests, and

iii Clear separation of information related to obtaining consent for data processing activities from

information about other matters.

56.

Ad. (i): Pursuant to Article 5(1)(b) GDPR, obtaining valid consent is always preceded by the determination of a specific, explicit and legitimate purpose for the intended processing activity.³⁰ The

need for specific consent in combination with the notion of purpose limitation in Article 5(1)(b)

functions as a safeguard against the gradual widening or blurring of purposes for which data is

processed, after a data subject has agreed to the initial collection of the data. This phenomenon, also

known as function creep, is a risk for data subjects, as it may result in unanticipated use of personal

data by the controller or by third parties and in loss of data subject control.

57. If the controller is relying on Article 6(1)(a), data subjects must always give consent for a specific

processing purpose.³¹ In line with the concept of *purpose limitation*, Article 5(1)(b) and recital 32,

consent may cover different operations, as long as these operations serve the same purpose.

It goes

without saying that specific consent can only be obtained when data subjects are specifically informed

about the intended purposes of data use concerning them.

58. Notwithstanding the provisions on compatibility of purposes, consent must be specific to the purpose.

Data subjects will give their consent with the understanding that they are in control and their data will

only be processed for those specified purposes. If a controller processes data based on consent and

wishes to process the data for another purpose, too, that controller needs to seek additional consent

for this other purpose unless there is another lawful basis, which better reflects the situation.

59. Example 11: A cable TV network collects subscribers' personal data, based on their consent, to present

them with personal suggestions for new movies they might be interested in based on their viewing

habits. After a while, the TV network decides it would like to enable third parties to send (or display)

targeted advertising on the basis of the subscriber's viewing habits. Given this new purpose, new

consent is needed.

60. **Ad. (ii):** Consent mechanisms must not only be granular to meet the requirement of 'free', but also to

meet the element of 'specific'. This means, a controller that seeks consent for various different

²⁹

Recital 43 GDPR states that separate consent for different processing operations will be needed wherever appropriate.

Granular consent options should be provided to allow data subjects to consent separately to separate purposes.

³⁰

See WP 29 Opinion 3/2013 on purpose limitation (WP 203), p. 16, : "*For these reasons, a purpose that is vague*

or general, such as for instance 'improving users' experience', 'marketing purposes', 'IT-security purposes' or 'future research' will - without more detail - usually not meet the criteria of being 'specific'."

³¹

This is consistent with WP29 Opinion 15/2011 on the definition of consent (WP 187), for example on p.

17.adopted

15

purposes should provide a separate opt-in for each purpose, to allow users to give specific consent for

specific purposes.

61. **Ad. (iii):** Lastly, controllers should provide specific information with each separate consent request

about the data that are processed for each purpose, in order to make data subjects aware of the impact of the different choices they have. Thus, data subjects are enabled to give specific consent. This issue overlaps with the requirement that controllers must provide clear information, as discussed in paragraph 3.3. below.

3.3 Informed

62. The GDPR reinforces the requirement that consent must be informed. Based on Article 5 of the GDPR, the requirement for transparency is one of the fundamental principles, closely related to the principles of fairness and lawfulness. Providing information to data subjects prior to obtaining their consent is essential in order to enable them to make informed decisions, understand what they are agreeing to, and for example exercise their right to withdraw their consent. If the controller does not provide accessible information, user control becomes illusory and consent will be an invalid basis for processing.

63. The consequence of not complying with the requirements for informed consent is that consent will be invalid and the controller may be in breach of Article 6 of the GDPR.

3.3.1

Minimum content requirements for consent to be 'informed'

64. For consent to be informed, it is necessary to inform the data subject of certain elements that are crucial to make a choice. Therefore, the EDPB is of the opinion that at least the following information is required for obtaining valid consent:

- i.
the controller's identity,³²
- ii.
the purpose of each of the processing operations for which consent is sought,³³
- iii.
what (type of) data will be collected and used,³⁴
- iv.
the existence of the right to withdraw consent,³⁵
- v.
information about the use of the data for automated decision-making in accordance with Article 22 (2)(c)³⁶ where relevant, and

³² See also Recital 42 GDPR: "[...]For consent to be informed, the data subject should be aware at least of the identity of the controller and the purposes of the processing for which the personal data are intended.[...]."

³³ Again, see Recital 42 GDPR.

³⁴ See also WP29 Opinion 15/2011 on the definition of consent (WP 187) pp.19-20.

³⁵ See Article 7(3) GDPR.

³⁶ See also WP29 Guidelines on Automated individual decision-making and Profiling for the purposes of Regulation 2016/679 (WP251), paragraph IV.B, p. 20 onwards.adopted

vi.

on the possible risks of data transfers due to absence of an adequacy decision and of appropriate safeguards as described in Article 46.³⁷

65. With regard to item (i) and (iii), the EDPB notes that in a case where the consent sought is to be relied

upon by multiple (joint) controllers or if the data is to be transferred to or processed by other

controllers who wish to rely on the original consent, these organisations should all be named.

Processors do not need to be named as part of the consent requirements, although to comply with

Articles 13 and 14 of the GDPR, controllers will need to provide a full list of recipients or categories of

recipients including processors. To conclude, the EDPB notes that depending on the circumstances and

context of a case, more information may be needed to allow the data subject to genuinely understand

the processing operations at hand.

[3.3.2 How to provide information](#)

66. The GDPR does not prescribe the form or shape in which information must be provided in order to

fulfil the requirement of informed consent. This means valid information may be presented in various

ways, such as written or oral statements, or audio or video messages. However, the GDPR puts several

requirements for informed consent in place, predominantly in Article 7(2) and Recital 32.

This leads to

a higher standard for the clarity and accessibility of the information.

67. When seeking consent, controllers should ensure that they use clear and plain language in all cases.

This means a message should be easily understandable for the average person and not only for

lawyers. Controllers cannot use long privacy policies that are difficult to understand or statements full

of legal jargon. Consent must be clear and distinguishable from other matters and provided in an

intelligible and easily accessible form. This requirement essentially means that information relevant

for making informed decisions on whether or not to consent may not be hidden in general terms and

conditions.³⁸

68. A controller must ensure that consent is provided on the basis of information that allows the data

subjects to easily identify who the controller is and to understand what they are agreeing to. The

controller must clearly describe the purpose for data processing for which consent is requested.³⁹

69. Other specific guidance on the accessibility has been provided in the WP29 guidelines on transparency.

If consent is to be given by electronic means, the request must be clear and concise. Layered and

granular information can be an appropriate way to deal with the two-fold obligation of being precise

and complete on the one hand and understandable on the other hand.

70. A controller must assess what kind of audience it is that provides personal data to their organisation.

For example, in case the targeted audience includes data subjects that are underage, the controller is

expected to make sure information is understandable for minors.⁴⁰ After identifying their audience,

³⁷

Pursuant to Article 49 (1)(a), specific information is required about the absence of safeguards described in Article 46, when explicit consent is sought. See also WP29 Opinion 15/2011 on the definition of consent (WP

187)p. 19.

³⁸

The declaration of consent must be named as such. Drafting, such as “I know that...” does not meet the requirement of clear language.

³⁹

See Articles 4(11) and 7(2) GDPR.

⁴⁰

See also Recital 58 regarding information understandable for children.adopted

17

controllers must determine what information they should provide and, subsequently how they will

present the information to data subjects.

71. Article 7(2) addresses pre-formulated written declarations of consent, which also concern other

matters. When consent is requested as part of a (paper) contract, the request for consent should be

clearly distinguishable from the other matters. If the paper contract includes many aspects that are

unrelated to the question of consent to the use of personal data, the issue of consent should be dealt

with in a way that clearly stands out, or in a separate document. Likewise, if consent is requested by

electronic means, the consent request has to be separate and distinct, it cannot simply be a paragraph

within terms and conditions, pursuant to Recital 32.⁴¹ To accommodate for small screens or situations

with restricted room for information, a layered way of presenting information can be considered,

where appropriate, to avoid excessive disturbance of user experience or product design.

72. A controller that relies on consent of the data subject must also deal with the separate information

duties laid down in Articles 13 and 14 in order to be compliant with the GDPR. In practice, compliance

with the information duties and compliance with the requirement of informed consent may lead to an

integrated approach in many cases. However, this section is written in the understanding that valid

“informed” consent can exist, even when not all elements of Articles 13 and/or 14 are mentioned in

the process of obtaining consent (these points should of course be mentioned in other places, such as

the privacy notice of a company). WP29 has issued separate guidelines on the requirement of transparency.

73. Example 12: Company X is a controller that received complaints that it is unclear to data subjects for

what purposes of data use they are asked to consent to. The company sees the need to verify whether

its information in the consent request is understandable for data subjects. X organises voluntary test

panels of specific categories of its customers and presents new updates of its consent information to

these test audiences before communicating it externally. The selection of the panel respects the

principle of independence and is made on the basis of standards ensuring a representative, non-biased

outcome. The panel receives a questionnaire and indicates what they understood of the information

and how they would score it in terms of understandable and relevant information. The controller

continues testing until the panels indicate that the information is understandable. X draws up a report

of the test and keeps this available for future reference. This example shows a possible way for X to

demonstrate that data subjects were receiving clear information before consenting to personal data

processing by X.

74. Example 13: A company engages in data processing on the basis of consent. The company uses a

layered privacy notice that includes a consent request. The company discloses all basic details of the

controller and the data processing activities envisaged.⁴² However, the company does not indicate how

their data protection officer can be contacted in the first information layer of the notice. For the

purposes of having a valid lawful basis as meant in Article 6, this controller obtained valid “informed”

⁴¹

See also Recital 42 and Directive 93/13/EC, notably Article 5 (plain intelligible language and in case of doubt, the interpretation will be in favour of consumer) and Article 6 (invalidity of unfair terms, contract continues to

exist without these terms only if still sensible, otherwise the whole contract is invalid).

⁴²

Note that when the identity of the controller or the purpose of the processing is not apparent from the first information layer of the layered privacy notice (and are located in further sub-layers), it will be difficult for the

data controller to demonstrate that the data subject has given informed consent, unless the data controller can

show that the data subject in question accessed that information prior to giving consent.adopted

18

consent, even when the contact details of the data protection officer have not been communicated to

the data subject (in the first information layer), pursuant to Article 13(1)(b) or 14(1)(b) GDPR.

3.4 Unambiguous indication of wishes

75. The GDPR is clear that consent requires a statement from the data subject or a clear affirmative act, which means that it must always be given through an active motion or declaration. It must be obvious that the data subject has consented to the particular processing.

76. Article 2(h) of Directive 95/46/EC described consent as an “indication of wishes by which the data subject signifies his agreement to personal data relating to him being processed”. Article 4(11) GDPR builds on this definition, by clarifying that valid consent requires an *unambiguous* indication by means of a *statement or by a clear affirmative action*, in line with previous guidance issued by the WP29.

77. A “clear affirmative act” means that the data subject must have taken a deliberate action to consent to the particular processing.⁴³ Recital 32 sets out additional guidance on this. Consent can be collected through a written or (a recorded) oral statement, including by electronic means.

78. Perhaps the most literal way to fulfil the criterion of a “written statement” is to make sure a data subject writes in a letter or types an email to the controller explaining what exactly he/she agrees to. However, this is often not realistic. Written statements can come in many shapes and sizes that could be compliant with the GDPR.

79. Without prejudice to existing (national) contract law, consent can be obtained through a recorded oral statement, although due note must be taken of the information available to the data subject, prior to the indication of consent. The use of pre-ticked opt-in boxes is invalid under the GDPR. Silence or inactivity on the part of the data subject, as well as merely proceeding with a service cannot be regarded as an active indication of choice.

80. Example 14: When installing software, the application asks the data subject for consent to use non-anonymised crash reports to improve the software. A layered privacy notice providing the necessary information accompanies the request for consent. By actively ticking the optional box stating, “I consent”, the user is able to validly perform a ‘clear affirmative act’ to consent to the processing.

81. A controller must also beware that consent cannot be obtained through the same motion as agreeing to a contract or accepting general terms and conditions of a service. Blanket acceptance of general terms and conditions cannot be seen as a clear affirmative action to consent to the use of personal

⁴³

See Commission Staff Working Paper, Impact Assessment, Annex 2, p. 20 and also pp. 105-106: “As also pointed

out in the opinion adopted by WP29 on consent, it seems essential to clarify that valid consent requires the use of mechanisms that leave no doubt of the data subject's intention to consent, while making clear that – in the context of the on-line environment – the use of default options which the data subject is required to modify in order to reject the processing ('consent based on silence') does not in itself constitute unambiguous consent. This would give individuals more control over their own data, whenever processing is based on his/her consent. As regards impact on data controllers, this would not have a major impact as it solely clarifies and better spells out the implications of the current Directive in relation to the conditions for a valid and meaningful consent from the data subject. In particular, to the extent that 'explicit' consent would clarify – by replacing "unambiguous" – the modalities and quality of consent and that it is not intended to extend the cases and situations where (explicit) consent should be used as a ground for processing, the impact of this measure on data controllers is not expected to be major." adopted

19

data. The GDPR does not allow controllers to offer pre-ticked boxes or opt-out constructions that

require an intervention from the data subject to prevent agreement (for example 'opt-out boxes').⁴⁴

82. When consent is to be given following a request by electronic means, the request for consent should not be *unnecessarily* disruptive to the use of the service for which the consent is provided.⁴⁵

An active

affirmative motion by which the data subject indicates consent can be necessary when a less infringing

or disturbing modus would result in ambiguity. Thus, it may be necessary that a consent request

interrupts the use experience to some extent to make that request effective.

83. However, within the requirements of the GDPR, controllers have the liberty to develop a consent flow

that suits their organisation. In this regard, physical motions can be qualified as a clear affirmative

action in compliance with the GDPR.

84. Controllers should design consent mechanisms in ways that are clear to data subjects. Controllers must

avoid ambiguity and must ensure that the action by which consent is given can be distinguished from

other actions. Therefore, merely continuing the ordinary use of a website is not conduct from which

one can infer an indication of wishes by the data subject to signify his or her agreement to a proposed

processing operation.

85. Example 15: Swiping a bar on a screen, waving in front of a smart camera, turning a smartphone

around clockwise, or in a figure eight motion may be options to indicate agreement, as long as clear

information is provided, and it is clear that the motion in question signifies agreement to a specific request (e.g. if you swipe this bar to the left, you agree to the use of information X for purpose Y.

Repeat the motion to confirm.”). The controller must be able to demonstrate that consent was

obtained this way and data subjects must be able to withdraw consent as easily as it was given.

86. Example 16: Based on recital 32, actions such as scrolling or swiping through a webpage or similar user

activity will not under any circumstances satisfy the requirement of a clear and affirmative action: such

actions may be difficult to distinguish from other activity or interaction by a user and therefore

determining that an unambiguous consent has been obtained will also not be possible.

Furthermore,

in such a case, it will be difficult to provide a way for the user to withdraw consent in a manner that is

as easy as granting it.

87. In the digital context, many services need personal data to function, hence, data subjects receive

multiple consent requests that need answers through clicks and swipes every day. This may result in a

certain degree of click fatigue: when encountered too many times, the actual warning effect of consent

mechanisms is diminishing.

88. This results in a situation where consent questions are no longer read. This is a particular risk to data

subjects, as, typically, consent is asked for actions that are in principle unlawful without their consent.

The GDPR places upon controllers the obligation to develop ways to tackle this issue.

89. An often-mentioned example to do this in the online context is to obtain consent of Internet users via

their browser settings. Such settings should be developed in line with the conditions for valid consent

⁴⁴

See Article 7(2). See also Working Document 02/2013 on obtaining consent for cookies (WP 208), pp. 3-6.

⁴⁵

See Recital 32 GDPR.adopted

20

in the GDPR, as for instance that the consent shall be granular for each of the envisaged purposes and

that the information to be provided, should name the controllers.

90. In any event, consent must always be obtained before the controller starts processing personal data

for which consent is needed. WP29 has consistently held in its opinions that consent should be given

prior to the processing activity.⁴⁶ Although the GDPR does not literally prescribe in Article 4(11) that

consent must be given prior to the processing activity, this is clearly implied. The heading of Article

6(1) and the wording “has given” in Article 6(1)(a) support this interpretation. It follows logically from

Article 6 and Recital 40 that a valid lawful basis must be present before starting a data processing.

Therefore, consent should be given prior to the processing activity. In principle, it can be sufficient to

ask for a data subject’s consent once. However, controllers do need to obtain a new and specific

consent if purposes for data processing change after consent was obtained or if an additional purpose

is envisaged.

4 OBTAINING EXPLICIT CONSENT

91. Explicit consent is required in certain situations where serious data protection risk emerge, hence,

where a high level of individual control over personal data is deemed appropriate. Under the GDPR,

explicit consent plays a role in Article 9 on the processing of special categories of data, the provisions

on data transfers to third countries or international organisations in the absence of adequate

safeguards in Article 49⁴⁷, and in Article 22 on automated individual decision-making, including

profiling.⁴⁸

92. The GDPR prescribes that a “statement or clear affirmative action” is a prerequisite for ‘regular’

consent. As the ‘regular’ consent requirement in the GDPR is already raised to a higher standard

compared to the consent requirement in Directive 95/46/EC, it needs to be clarified what extra efforts

a controller should undertake in order to obtain the *explicit* consent of a data subject in line with the

GDPR.

93. The term *explicit* refers to the way consent is expressed by the data subject. It means that the data

subject must give an express statement of consent. An obvious way to make sure consent is explicit

would be to expressly confirm consent in a written statement. Where appropriate, the controller could

⁴⁶

WP29 has consistently held this position since Opinion 15/2011 on the definition of consent (WP 187), pp. 30-

31.

⁴⁷

According to Article 49 (1)(a) GDPR, explicit consent can lift the ban on data transfers to countries without adequate levels of data protection law. Also note Working document on a common interpretation of Article 26(1)

of Directive 95/46/EC of 24 October 1995 (WP 114), p. 11, where WP29 has indicated that consent for data transfers that occur periodically or on an on-going basis is inappropriate.

⁴⁸

In Article 22, the GDPR introduces provisions to protect data subjects against decision-making based solely on

automated processing, including profiling. Decisions made on this basis are allowed under certain legal conditions. Consent plays a key role in this protection mechanism, as Article 22(2)(c) GDPR makes clear that a

controller may proceed with automated decision making, including profiling, that may significantly affect the individual, with the data subject's explicit consent. WP29 have produced separate guidelines on this issue: WP29

Guidelines on Automated decision-making and Profiling for the purposes of Regulation 2016/679, 3 October 2017

(WP 251).adopted

21

make sure the written statement is signed by the data subject, in order to remove all possible doubt

and potential lack of evidence in the future.⁴⁹

94. However, such a signed statement is not the only way to obtain explicit consent and, it cannot be said

that the GDPR prescribes written and signed statements in all circumstances that require valid explicit

consent. For example, in the digital or online context, a data subject may be able to issue the required

statement by filling in an electronic form, by sending an email, by uploading a scanned document

carrying the signature of the data subject, or by using an electronic signature. In theory, the use of oral

statements can also be sufficiently express to obtain valid explicit consent, however, it may be difficult

to prove for the controller that all conditions for valid explicit consent were met when the statement

was recorded.

95. An organisation may also obtain explicit consent through a telephone conversation, provided that the

information about the choice is fair, intelligible and clear, and it asks for a specific confirmation from

the data subject (e.g. pressing a button or providing oral confirmation).

96. Example 17: A data controller may also obtain explicit consent from a visitor to its website by offering

an explicit consent screen that contains Yes and No check boxes, provided that the text clearly indicates

the consent, for instance "I, hereby, consent to the processing of my data", and not for instance, "It is

clear to me that my data will be processed". It goes without saying that the conditions for informed

consent as well as the other conditions for obtaining valid consent should be met.

97. Example 18: A clinic for cosmetic surgery seeks explicit consent from a patient to transfer his medical

record to an expert whose second opinion is asked on the condition of the patient. The medical record

is a digital file. Given the specific nature of the information concerned, the clinic asks for an electronic

signature of the data subject to obtain valid explicit consent and to be able to demonstrate that explicit

consent was obtained.⁵⁰

98. Two stage verification of consent can also be a way to make sure explicit consent is valid. For example,

a data subject receives an email notifying them of the controller's intent to process a record containing medical data. The controller explains in the email that he asks for consent for the use of a specific set of information for a specific purpose. If the data subjects agrees to the use of this data, the controller asks him or her for an email reply containing the statement 'I agree'. After the reply is sent, the data subject receives a verification link that must be clicked, or an SMS message with a verification code, to confirm agreement.

99. Article 9(2) does not recognize "necessary for the performance of a contract" as an exception to the general prohibition to process special categories of data. Therefore, controllers and Member States that deal with this situation should explore the specific exceptions in Article 9(2) subparagraphs (b) to (j). Should none of the exceptions (b) to (j) apply, obtaining explicit consent in accordance with the conditions for valid consent in the GDPR remains the only possible lawful exception to process such data.

⁴⁹

See also WP29 Opinion 15/2011, on the definition of consent (WP 187), p. 25.

⁵⁰

This example is without prejudice to EU Regulation (EU) No 910/2014 of the European Parliament and of the Council of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market. adopted

22

100. Example 19: An airline company, Holiday Airways, offers an assisted travelling service for passengers that cannot travel unassisted, for example due to a disability. A customer books a flight from Amsterdam to Budapest and requests travel assistance to be able to board the plane. Holiday Airways requires her to provide information on her health condition to be able to arrange the appropriate services for her (hence, there are many possibilities e.g. wheelchair on the arrival gate, or an assistant travelling with her from A to B.) Holiday Airways asks for explicit consent to process the health data of this customer for the purpose of arranging the requested travel assistance. -The data processed on the basis of consent should be necessary for the requested service. Moreover, flights to Budapest remain available without travel assistance. Please note that since that data are necessary for the provision of the requested service, Article 7 (4) does not apply.

101. Example 20: A successful company is specialised in providing custom-made ski- and snowboard goggles, and other types of customised eyewear for outdoors sports. The idea is that people could

wear these without their own glasses on. The company receives orders at a central point and delivers products from a single location all across the EU.

102. In order to be able to provide its customised products to customers who are short-sighted, this controller requests consent for the use of information on customers' eye condition. Customers provide the necessary health data, such as their prescription data online when they place their order. Without this, it is not possible to provide the requested customized eyewear. The company also offers series of goggles with standardized correctional values. Customers that do not wish to share health data could opt for the standard versions. Therefore, an explicit consent under Article 9 is required and consent can be considered to be freely given.

5 ADDITIONAL CONDITIONS FOR OBTAINING VALID CONSENT

103. The GDPR introduces requirements for controllers to make additional arrangements to ensure they obtain, and maintain and are able to demonstrate, valid consent. Article 7 of the GDPR sets out these additional conditions for valid consent, with specific provisions on keeping records of consent and the right to easily withdraw consent. Article 7 also applies to consent referred to in other articles of GDPR, e.g. Articles 8 and 9. Guidance on the additional requirement to demonstrate valid consent and on withdrawal of consent is provided below.

5.1 Demonstrate consent

104. In Article 7(1), the GDPR clearly outlines the explicit obligation of the controller to demonstrate a data subject's consent. The burden of proof will be on the controller, according to Article 7(1).

105. Recital 42 states: *"Where processing is based on the data subject's consent, the controller should be able to demonstrate that the data subject has given consent to the processing operation."*

106. Controllers are free to develop methods to comply with this provision in a way that is fitting in their daily operations. At the same time, the duty to demonstrate that valid consent has been obtained by a controller, should not in itself lead to excessive amounts of additional data processing. This means that controllers should have enough data to show a link to the processing (to show consent was obtained) but they shouldn't be collecting any more information than necessary.

107. It is up to the controller to prove that valid consent was obtained from the data subject. The GDPR does not prescribe exactly how this must be done. However, the controller must be able to prove that

a data subject in a given case has consented. As long as a data processing activity in question lasts, the adopted

obligation to demonstrate consent exists. After the processing activity ends, proof of consent should be kept no longer than strictly necessary for compliance with a legal obligation or for the establishment, exercise or defence of legal claims, in accordance with Article 17(3)(b) and (e). 108. For instance, the controller may keep a record of consent statements received, so he can show how consent was obtained, when consent was obtained and the information provided to the data subject at the time shall be demonstrable. The controller shall also be able to show that the data subject was informed and the controller's workflow met all relevant criteria for a valid consent. The rationale behind this obligation in the GDPR is that controllers must be accountable with regard to obtaining valid consent from data subjects and the consent mechanisms they have put in place. For example, in an online context, a controller could retain information on the session in which consent was expressed, together with documentation of the consent workflow at the time of the session, and a copy of the information that was presented to the data subject at that time. It would not be sufficient to merely refer to a correct configuration of the respective website.

109. Example 21: A hospital sets up a scientific research programme, called project X, for which dental records of real patients are necessary. Participants are recruited via telephone calls to patients that voluntarily agreed to be on a list of candidates that may be approached for this purpose. The controller seeks explicit consent from the data subjects for the use of their dental record. Consent is obtained during a phone call by recording an oral statement of the data subject in which the data subject confirms that they agree to the use of their data for the purposes of project X.

110. There is no specific time limit in the GDPR for how long consent will last. How long consent lasts will depend on the context, the scope of the original consent and the expectations of the data subject. If the processing operations change or evolve considerably then the original consent is no longer valid.

If this is the case, then new consent needs to be obtained.

111. The EDPB recommends as a best practice that consent should be refreshed at appropriate intervals.

Providing all the information again helps to ensure the data subject remains well informed about how their data is being used and how to exercise their rights.⁵¹

[5.2 Withdrawal of consent](#)

112. Withdrawal of consent is given a prominent place in the GDPR. The provisions and recitals on withdrawal of consent in the GDPR can be regarded as codification of the existing interpretation of this

matter in WP29 Opinions.⁵²

113. Article 7(3) of the GDPR prescribes that the controller must ensure that consent can be withdrawn by the data subject as easy as giving consent and at any given time. The GDPR does not say that giving and withdrawing consent must always be done through the same action.

114. However, when consent is obtained via electronic means through only one mouse-click, swipe, or keystroke, data subjects must, in practice, be able to withdraw that consent equally as easily. Where

⁵¹

See Article 29 Working Party guidelines on transparency under Regulation 2016/679 WP260 rev.01 - endorsed by the EDPB.

⁵²

WP29 has discussed this subject in their Opinion on consent (see Opinion 15/2011 on the definition of consent

(WP 187), pp. 9, 13, 20, 27 and 32-33) and, inter alia, their Opinion on the use of location data. (see Opinion

5/2005 on the use of location data with a view to providing value-added services (WP 115), p. 7).adopted

24

consent is obtained through use of a service-specific user interface (for example, via a website, an app, a log-on account, the interface of an IoT device or by e-mail), there is no doubt a data subject must be able to withdraw consent via the same electronic interface, as switching to another interface for the sole reason of withdrawing consent would require undue effort. Furthermore, the data subject should be able to withdraw his/her consent without detriment. This means, inter alia, that a controller must

make withdrawal of consent possible free of charge or without lowering service levels.⁵³

115. Example 22: A music festival sells tickets through an online ticket agent. With each online ticket sale, consent is requested in order to use contact details for marketing purposes. To indicate consent for this purpose, customers can select either No or Yes. The controller informs customers that they have the possibility to withdraw consent. To do this, they could contact a call centre on business days between 8am and 5pm, free of charge. The controller in this example does not comply with article 7(3) of the GDPR. Withdrawing consent in this case requires a telephone call during business hours, this is more burdensome than the one mouse-click needed for giving consent through the online ticket vendor, which is open 24/7.

116. The requirement of an easy withdrawal is described as a necessary aspect of valid consent in the GDPR.

If the withdrawal right does not meet the GDPR requirements, then the consent mechanism of the controller does not comply with the GDPR. As mentioned in section 3.1 on the condition of *informed*

consent, the controller must inform the data subject of the right to withdraw consent prior to actually giving consent, pursuant to Article 7(3) of the GDPR. Additionally, the controller must as part of the

transparency obligation inform the data subjects on how to exercise their rights.⁵⁴

117. As a general rule, if consent is withdrawn, all data processing operations that were based on consent and took place before the withdrawal of consent - and in accordance with the GDPR - remain lawful,

however, the controller must stop the processing actions concerned. If there is no other lawful basis

justifying the processing (e.g. further storage) of the data, they should be deleted by the controller.⁵⁵

118. As mentioned earlier in these guidelines, it is very important that controllers assess the purposes for

which data is actually processed and the lawful grounds on which it is based prior to collecting the

data. Often companies need personal data for several purposes, and the processing is based on more

than one lawful basis, e.g. customer data may be based on contract and consent. Hence, a withdrawal

of consent does not mean a controller must erase data that are processed for a purpose that is based

on the performance of the contract with the data subject. Controllers should therefore be clear from

the outset about which purpose applies to each element of data and which lawful basis is being relied

upon.

⁵³

See also opinion WP29 Opinion 4/2010 on the European code of conduct of FEDMA for the use of personal data in direct marketing (WP 174) and the Opinion on the use of location data with a view to providing value-added services (WP 115).

⁵⁴

Recital 39 GDPR, which refers to Articles 13 and 14 of that Regulation, states that *“natural persons should be made aware of risks, rules, safeguards and rights in relation to the processing of personal data and how to exercise their rights in relation to such processing.”*

⁵⁵

See Article 17(1)(b) and (3) GDPR.

119. Controllers have an obligation to delete data that was processed on the basis of consent once that

consent is withdrawn, assuming that there is no other purpose justifying the continued retention.⁵⁶

Besides this situation, covered in Article 17 (1)(b), an individual data subject may request erasure of

other data concerning him that is processed on another lawful basis, e.g. on the basis of Article

6(1)(b).⁵⁷ Controllers are obliged to assess whether continued processing of the data in question is

appropriate, even in the absence of an erasure request by the data subject.⁵⁸

120. In cases where the data subject withdraws his/her consent and the controller wishes to continue to

process the personal data on another lawful basis, they cannot silently migrate from consent (which is withdrawn) to this other lawful basis. Any change in the lawful basis for processing must be notified to a data subject in accordance with the information requirements in Articles 13 and 14 and under the general principle of transparency.

6 INTERACTION BETWEEN CONSENT AND OTHER LAWFUL GROUNDS IN ARTICLE 6 GDPR

121. Article 6 sets the conditions for a lawful personal data processing and describes six lawful bases on which a controller can rely. The application of one of these six bases must be established prior to the processing activity and in relation to a specific purpose.⁵⁹

122. It is important to note here that if a controller chooses to rely on consent for any part of the processing, they must be prepared to respect that choice and stop that part of the processing if an individual

withdraws consent. Sending out the message that data will be processed on the basis of consent, while actually some other lawful basis is relied on, would be fundamentally unfair to individuals.

123. In other words, the controller cannot swap from consent to other lawful bases. For example, it is not allowed to retrospectively utilise the legitimate interest basis in order to justify processing, where

problems have been encountered with the validity of consent. Because of the requirement to disclose

the lawful basis, which the controller is relying upon at the time of collection of personal data,

controllers must have decided in advance of collection what the applicable lawful basis is.

7 SPECIFIC AREAS OF CONCERN IN THE GDPR

7.1 Children (Article 8)

124. Compared to the current directive, the GDPR creates an additional layer of protection where personal

data of vulnerable natural persons, especially children, are processed. Article 8 introduces additional

obligations to ensure an enhanced level of data protection of children in relation to information society

services. The reasons for the enhanced protection are specified in Recital 38: “*[...] they may be less*

aware of the risks, consequences and safeguards concerned and their rights in relation to the

⁵⁶

In that case, the other purpose justifying the processing must have its own separate legal basis. This does not

mean the controller can swap from consent to another lawful basis, see section 6 below.

⁵⁷

See Article 17, including exceptions that may apply, and Recital 65 GDPR.

⁵⁸

See also Article 5 (1)(e) GDPR.

⁵⁹

Pursuant to Articles 13 (1)(c) and/or 14(1)(c), the controller must inform the data subject thereof.^{adopted}
26

processing of personal data [...]” Recital 38 also states that *“Such specific protection should, in*

particular, apply to the use of personal data of children for the purposes of marketing or creating

personality or user profiles and the collection of personal data with regard to children when using

services offered directly to a child.” The words ‘in particular’ indicate that the specific protection is not

confined to marketing or profiling but includes the wider ‘collection of personal data with regard to

children’.

125. Article 8(1) states that where consent applies, in relation to the offer of information society services

directly to a child, the processing of the personal data of a child shall be lawful where the child is at

least 16 years old. Where the child is below the age of 16 years, such processing shall be lawful only if

and to the extent that consent is given or authorised by the holder of parental responsibility over the

child.⁶⁰ Regarding the age limit of valid consent the GDPR provides flexibility, Member States can

provide by law a lower age, but this age cannot be below 13 years.

126. As mentioned in section 3.1. on informed consent, the information shall be understandable to the

audience addressed by the controller, paying particular attention to the position of children.

In order

to obtain “informed consent” from a child, the controller must explain in language that is clear and

plain for children how it intends to process the data it collects.⁶¹ If it is the parent that is supposed to

consent, then a set of information may be required that allows adults to make an informed decision.

127. It is clear from the foregoing that Article 8 shall only apply when the following conditions are met:

- The processing is related to the offer of information society services directly to a child.^{62, 63}
- The processing is based on consent.

7.1.1 Information society service

128. To determine the scope of the term ‘information society service’ in the GDPR, reference is made in

Article 4(25) GDPR to Directive 2015/1535.

⁶⁰

Without prejudice to the possibility of Member State law to derogate from the age limit, see Article 8(1).

⁶¹

Recital 58 GDPR re-affirms this obligation, in stating that, where appropriate, a controller should make sure the information provided is understandable for children.

⁶²

According to Article 4(25) GDPR an information society service means a service as defined in point (b) of Article

1(1) of Directive 2015/1535: “(b) ‘service’ means any Information Society service, that is to say, any service normally provided for remuneration, at a distance, by electronic means and at the individual request of a recipient

of services. For the purposes of this definition: (i) 'at a distance' means that the service is provided without the parties being simultaneously present; (ii) 'by electronic means' means that the service is sent initially and received at its destination by means of electronic equipment for the processing (including digital compression) and storage of data, and entirely transmitted, conveyed and received by wire, by radio, by optical means or by other electromagnetic means; (iii) 'at the individual request of a recipient of services' means that the service is provided through the transmission of data on individual request." An indicative list of services not covered by this definition

is set out in Annex I of the said Directive. See also Recital 18 of Directive 2000/31.

⁶³ According to the UN Convention on the Protection of the Child, Article 1, "[...] a child means every human being below the age of eighteen years unless under the law applicable to the child, majority is attained earlier," see

United Nations, General Assembly Resolution 44/25 of 20 November 1989 (Convention on the Rights of the Child). adopted

27

129. While assessing the scope of this definition, the EDPB also refers to case law of the ECJ.⁶⁴ The ECJ held

that *information society services* cover contracts and other services that are concluded or transmitted

on-line. Where a service has two economically independent components, one being the online

component, such as the offer and the acceptance of an offer in the context of the conclusion of a

contract or the information relating to products or services, including marketing activities, this

component is defined as an information society service, the other component being the physical

delivery or distribution of goods is not covered by the notion of an information society service. The

online delivery of a service would fall within the scope of the term *information society service* in Article

8 GDPR.

7.1.2 Offered directly to a child

130. The inclusion of the wording 'offered directly to a child' indicates that Article 8 is intended to apply to

some, not all information society services. In this respect, if an information society service provider

makes it clear to potential users that it is only offering its service to persons aged 18 or over, and this

is not undermined by other evidence (such as the content of the site or marketing plans) then the

service will not be considered to be 'offered directly to a child' and Article 8 will not apply.

7.1.3 Age

131. The GDPR specifies that "*Member States may provide by law for a lower age for those purposes*

provided that such lower age is not below 13 years." The controller must be aware of those different

national laws, by taking into account the public targeted by its services. In particular, it should be noted

that a controller providing a cross-border service cannot always rely on complying with only the law of the Member State in which it has its main establishment but may need to comply with the respective national laws of each Member State in which it offers the information society service(s). This depends on whether a Member State chooses to use the place of main establishment of the controller as a point of reference in its national law, or the residence of the data subject. First of all the Member States shall consider the best interests of the child during making their choice. The Working Group encourages the Member States to search for a harmonized solution in this matter.

132. When providing information society services to children on the basis of consent, controllers will be expected to make reasonable efforts to verify that the user is over the age of digital consent, and these

measures should be proportionate to the nature and risks of the processing activities.

133. If the users state that they are over the age of digital consent then the controller can carry out

appropriate checks to verify that this statement is true. Although the need to undertake reasonable

efforts to verify age is not explicit in the GDPR it is implicitly required, for if a child gives consent while

not old enough to provide valid consent on their own behalf, then this will render the processing of data unlawful.

134. If the user states that he/she is below the age of digital consent then the controller can accept this

statement without further checks, but will need to go on to obtain parental authorisation and verify

that the person providing that consent is a holder of parental responsibility.

⁶⁴

See European Court of Justice, 2 December 2010 Case C-108/09, (*Ker-Optika*), paragraphs 22 and 28. In relation

to 'composite services', the EDPB also refers to Case C-434/15 (*Asociacion Profesional Elite Taxi v Uber Systems*

Spain SL), para 40, which states that an information society service forming an integral part of an overall service

whose main component is not an information society service (in this case a transport service), must not be qualified as 'an information society service'.adopted

28

135. Age verification should not lead to excessive data processing. The mechanism chosen to verify the age

of a data subject should involve an assessment of the risk of the proposed processing. In some low-risk

situations, it may be appropriate to require a new subscriber to a service to disclose their year of birth

or to fill out a form stating they are (not) a minor.⁶⁵ If doubts arise, the controller should review their

age verification mechanisms in a given case and consider whether alternative checks are required.⁶⁶

7.1.4 Children's consent and parental responsibility

136. Regarding the authorisation of a holder of parental responsibility, the GDPR does not specify practical ways to gather the parent's consent or to establish that someone is entitled to perform this action.⁶⁷

Therefore, the EDPB recommends the adoption of a proportionate approach, in line with Article 8(2)

GDPR and Article 5(1)(c) GDPR (data minimisation). A proportionate approach may be to focus on

obtaining a limited amount of information, such as contact details of a parent or guardian.

137. What is reasonable, both in terms of verifying that a user is old enough to provide their own consent,

and in terms of verifying that a person providing consent on behalf of a child is a holder of parental

responsibility, may depend upon the risks inherent in the processing as well as the available technology. In low-risk cases, verification of parental responsibility via email may be sufficient.

Conversely, in high-risk cases, it may be appropriate to ask for more proof, so that the controller is able

to verify and retain the information pursuant to Article 7(1) GDPR.⁶⁸ Trusted third party verification

services may offer solutions, which minimise the amount of personal data the controller has to process

itself.

138. Example 23: An online gaming platform wants to make sure underage customers only subscribe to its

services with the consent of their parents or guardians. The controller follows these steps:

139. Step 1: ask the user to state whether they are under or over the age of 16 (or alternative age of digital

consent) If the user states that they are under the age of digital consent:

140. Step 2: service informs the child that a parent or guardian needs to consent or authorise the processing

before the service is provided to the child. The user is requested to disclose the email address of a

parent or guardian.

141. Step 3: service contacts the parent or guardian and obtains their consent via email for processing and

take reasonable steps to confirm that the adult has parental responsibility.

142. Step 4: in case of complaints, the platform takes additional steps to verify the age of the subscriber.

⁶⁵

Although this may not be a watertight solution in all cases, it is an example to deal with this provision

⁶⁶

See WP29 Opinion 5/2009 on social networking services (WP 163).

⁶⁷

WP 29 notes that it not always the case that the holder of parental responsibility is the natural parent of the

child and that parental responsibility can be held by multiple parties which may include legal as well as natural

persons.

⁶⁸

For example, a parent or guardian could be asked to make a payment of €0,01 to the controller via a bank transaction, including a brief confirmation in the description line of the transaction that the bank account holder

is a holder of parental responsibility over the user. Where appropriate, an alternative method of verification

should be provided to prevent undue discriminatory treatment of persons that do not have a bank account.adopted

29

143. If the platform has met the other consent requirements, the platform can comply with the additional criteria of Article 8 GDPR by following these steps.

144. The example shows that the controller can put itself in a position to show that reasonable efforts have been made to ensure that valid consent has been obtained, in relation to the services provided to a child. Article 8(2) particularly adds that *“The controller shall make reasonable efforts to verify that consent is given or authorised by the holder of parental responsibility over the child, taking into consideration available technology.”*

145. It is up to the controller to determine what measures are appropriate in a specific case. As a general rule, controllers should avoid verification solutions which themselves involve excessive collection of personal data.

146. The EDPB acknowledges that there may be cases where verification is challenging (for example where children providing their own consent have not yet established an ‘identity footprint’, or where parental responsibility is not easily checked. This can be taken into account when deciding what efforts are reasonable, but controllers will also be expected to keep their processes and the available technology under constant review.

147. With regard to the data subject’s autonomy to consent to the processing of their personal data and have full control over the processing, consent by a holder of parental responsibility or authorized by a holder of parental responsibility for the processing of personal data of children can be confirmed, modified or withdrawn, once the data subject reaches the age of digital consent.

148. In practice, this means that if the child does not take any action, consent given by a holder of parental responsibility or authorized by a holder of parental responsibility for the processing of personal data given prior to the age of digital consent, will remain a valid ground for processing.

149. After reaching the age of digital consent, the child will have the possibility to withdraw the consent himself, in line with Article 7(3). In accordance with the principles of fairness and accountability, the controller must inform the child about this possibility.⁶⁹

150. It is important to point out that in accordance with Recital 38, consent by a parent or guardian is not required in the context of preventive or counselling services offered directly to a child. For example the provision of child protection services offered online to a child by means of an online chat service

do not require prior parental authorisation.

151. Finally, the GDPR states that the rules concerning parental authorization requirements vis-à-vis minors shall not interfere with “the general contract law of Member States such as the rules on the validity, formation or effect of a contract in relation to a child”. Therefore, the requirements for valid consent for the use of data about children are part of a legal framework that must be regarded as separate from national contract law. Therefore, this guidance paper does not deal with the question whether it is lawful for a minor to conclude online contracts. Both legal regimes may apply simultaneously, and, the scope of the GDPR does not include harmonization of national provisions of contract law.

⁶⁹ Also, data subjects should be aware of the right to be forgotten as laid down in Article 17, which is in particular

relevant for consent given when the data subject was still a child, see recital 63.adopted

30

152.

7.2 Scientific research

153. The definition of scientific research purposes has substantial ramifications for the range of data

processing activities a controller may undertake. The term ‘*scientific research*’ is not defined in the

GDPR. Recital 159 states “(...) *For the purposes of this Regulation, the processing of personal data for*

scientific research purposes should be interpreted in a broad manner. (...)”, however the EDPB

considers the notion may not be stretched beyond its common meaning and understands that

‘*scientific research*’ in this context means a research project set up in accordance with relevant sector-

related methodological and ethical standards, in conformity with good practice.

154. When consent is the legal basis for conducting research in accordance with the GDPR, this consent for

the use of personal data should be distinguished from other consent requirements that serve as an

ethical standard or procedural obligation. An example of such a procedural obligation, where the

processing is based not on consent but on another legal basis, is to be found in the Clinical Trials

Regulation. In the context of data protection law, the latter form of consent could be considered as an

additional safeguard.⁷⁰ At the same time, the GDPR does not restrict the application of Article 6 to

consent alone, with regard to processing data for research purposes. As long as appropriate safeguards

are in place, such as the requirements under Article 89(1), and the processing is fair, lawful, transparent

and accords with data minimisation standards and individual rights, other lawful bases such as Article

6(1)(e) or (f) may be available.⁷¹ This also applies to special categories of data pursuant to the derogation of Article 9(2)(j).⁷²

155. Recital 33 seems to bring some flexibility to the degree of specification and granularity of consent in the context of scientific research. Recital 33 states: *“It is often not possible to fully identify the purpose of personal data processing for scientific research purposes at the time of data collection. Therefore, data subjects should be allowed to give their consent to certain areas of scientific research when in keeping with recognised ethical standards for scientific research. Data subjects should have the opportunity to give their consent only to certain areas of research or parts of research projects to the extent allowed by the intended purpose.”*

156. First, it should be noted that Recital 33 does not disapply the obligations with regard to the requirement of specific consent. This means that, in principle, scientific research projects can only include personal data on the basis of consent if they have a well-described purpose. For the cases where purposes for data processing within a scientific research project cannot be specified at the outset, Recital 33 allows as an exception that the purpose may be described at a more general level.

157. Considering the strict conditions stated by Article 9 GDPR regarding the processing of special categories of data, the EDPB notes that when special categories of data are processed on the basis of explicit

⁷⁰
See also Recital 161 of the GDPR.

⁷¹
Article 6(1)(c) may also be applicable for parts of the processing operations specifically required by law, such as gathering reliable and robust data following the protocol as approved by the Member State under the Clinical Trial Regulation.

⁷²
Specific testing of medicinal products may take place on the basis of an EU or national law pursuant to Article

9(2)(i).adopted

31

consent, applying the flexible approach of Recital 33 will be subject to a stricter interpretation and requires a high degree of scrutiny.

158. When regarded as a whole, the GDPR cannot be interpreted to allow for a controller to navigate around the key principle of specifying purposes for which consent of the data subject is asked.

159. When research purposes cannot be fully specified, a controller must seek other ways to ensure the essence of the consent requirements are served best, for example, to allow data subjects to consent for a research purpose in more general terms and for specific stages of a research project that are

already known to take place at the outset. As the research advances, consent for subsequent steps in the project can be obtained before that next stage begins. Yet, such a consent should still be in line with the applicable ethical standards for scientific research.

160. Moreover, the controller may apply further safeguards in such cases. Article 89(1), for example,

highlights the need for safeguards in data processing activities for scientific or historical or statistical

purposes. These purposes *“shall be subject to appropriate safeguards, in accordance with this*

regulation, for the rights and freedoms of data subject.” Data minimization, anonymisation and data

security are mentioned as possible safeguards.⁷³ Anonymisation is the preferred solution as soon as

the purpose of the research can be achieved without the processing of personal data.

161. Transparency is an additional safeguard when the circumstances of the research do not allow for a

specific consent. A lack of purpose specification may be offset by information on the development of

the purpose being provided regularly by controllers as the research project progresses so that, over

time, the consent will be as specific as possible. When doing so, the data subject has at least a basic

understanding of the state of play, allowing him/her to assess whether or not to use, for example, the

right to withdraw consent pursuant to Article 7(3).⁷⁴

162. Also, having a comprehensive research plan available for data subjects to take note of, before they

consent could help to compensate a lack of purpose specification.⁷⁵ This research plan should specify

the research questions and working methods envisaged as clearly as possible. The research plan could

also contribute to compliance with Article 7(1), as controllers need to show what information was

⁷³

See for example Recital 156. The processing of personal data for scientific purposes should also comply with

other relevant legislation such as on clinical trials, see Recital 156, mentioning Regulation (EU) No 536/2014 of

the European Parliament and of the Council of 16 April 2014 on clinical trials on medicinal products for human

use. See also WP29 Opinion 15/2011 on the definition of consent (WP 187), p. 7: *“Moreover, obtaining consent*

does not negate the controller’s obligations under Article 6 with regard to fairness, necessity and proportionality,

as well as data quality. For instance, even if the processing of personal data is based on the consent of the user,

this would not legitimise the collection of data which is excessive in relation to a particular purpose.” [...] As a

principle, consent should not be seen as an exemption from the other data protection principles, but as a safeguard. It is primarily a ground for lawfulness, and it does not waive the application of other principles.”

⁷⁴

Other transparency measures may also be relevant. When controllers engage in data processing for scientific

purposes, while full information cannot be provided at the outset, they could designate a specific contact person for data subjects to address with questions.

⁷⁵

Such a possibility can be found in Article 14(1) of the current Personal Data Act of Finland (*Henkilötietolaki*, 523/1999). adopted

32

available to data subjects at the time of consent in order to be able to demonstrate that consent is valid.

163. It is important to recall that where consent is being used as the lawful basis for processing there must be a possibility for a data subject to withdraw that consent. The EDPB notes that withdrawal of consent could undermine types scientific research that require data that can be linked to individuals, however the GDPR is clear that consent can be withdrawn and controllers must act upon this – there is no exemption to this requirement for scientific research. If a controller receives a withdrawal request, it must in principle delete the personal data straight away if it wishes to continue to use the data for the purposes of the research.⁷⁶

7.3 Data subject's rights

164. If a data processing activity is based on a data subject's consent, this will affect that individual's rights. Data subjects may have the right to data portability (Article 20) when processing is based on consent. At the same time, the right to object (Article 21) does not apply when processing is based on consent, although the right to withdraw consent at any time may provide a similar outcome. 165. Articles 16 to 20 of the GDPR indicate that (when data processing is based on consent), data subjects have the right to erasure when consent has been withdrawn and the rights to restriction, rectification and access.⁷⁷

8 CONSENT OBTAINED UNDER DIRECTIVE 95/46/EC

166. Controllers that currently process data on the basis of consent in compliance with national data protection law are not automatically required to completely refresh all existing consent relations with data subjects in preparation for the GDPR. Consent, which has been obtained, to date continues to be valid in so far as it is in line with the conditions laid down in the GDPR. 167. It is important for controllers to review current work processes and records in detail, before 25 May 2018, to be sure existing consents meet the GDPR standard (see Recital 171 of the GDPR⁷⁸). In practice, the GDPR raises the bar with regard to implementing consent mechanisms and introduces several new

⁷⁶

See also WP29 Opinion 05/2014 on "Anonymisation Techniques" (WP216).

⁷⁷

In cases where certain data processing activities are restricted in accordance with Article 18, GDPR, consent of the data subject may be needed to lift restrictions.

⁷⁸

Recital 171 GDPR states: *“Directive 95/46/EC should be repealed by this Regulation. Processing already under way on the date of application of this Regulation should be brought into conformity with this Regulation within the period of two years after which this Regulation enters into force. Where processing is based on consent pursuant to Directive 95/46/EC, it is not necessary for the data subject to give his or her consent again if the manner in which the consent has been given is in line with the conditions of this Regulation, so as to allow the controller to continue such processing after the date of application of this Regulation. Commission decisions adopted and authorisations by supervisory authorities based on Directive 95/46/EC remain in force until amended, replaced or repealed.”* adopted

33

requirements that require controllers to alter consent mechanisms, rather than rewriting privacy policies alone.⁷⁹

168. For example, as the GDPR requires that a controller must be able to demonstrate that valid consent

was obtained, all presumed consents of which no references are kept will automatically be below the

consent standard of the GDPR and will need to be renewed. Likewise as the GDPR requires a “statement or a clear affirmative action”, all presumed consents that were based on a more implied

form of action by the data subject (e.g. a pre-ticked opt-in box) will also not be apt to the GDPR

standard of consent.

169. Furthermore, to be able to demonstrate that consent was obtained or to allow for more granular

indications of the data subject’s wishes, operations and IT systems may need revision. Also, mechanisms for data subjects to withdraw their consent easily must be available and information

about how to withdraw consent must be provided. If existing procedures for obtaining and managing

consent do not meet the GDPR’s standards, controllers will need to obtain fresh GDPR compliant consent.

170. On the other hand, as not all elements named in Articles 13 and 14 must always be present as a

condition for informed consent, the extended information obligations under the GDPR do not

necessarily oppose the continuity of consent, which has been granted before the GDPR enters into

force (see page 15 above). Under Directive 95/46/EC, there was no requirement to inform data

subjects of the basis upon which the processing was being conducted.

171. If a controller finds that the consent previously obtained under the old legislation will not meet the

standard of GDPR consent, then controllers must undertake action to comply with these standards, for

example by refreshing consent in a GDPR-compliant way. Under the GDPR, it is not possible to swap

between one lawful basis and another. If a controller is unable to renew consent in a compliant way and is also unable – as a one off situation- to make the transition to GDPR compliance by basing data processing on a different lawful basis while ensuring that continued processing is fair and accounted for, the processing activities must be stopped. In any event, the controller needs to observe the principles of lawful, fair and transparent processing.

⁷⁹

As indicated in the introduction, the GDPR provides further clarification and specification of the requirements for obtaining and demonstrating valid consent. Many of the new requirements build upon Opinion 15/2011 on consent.